

SIMATS ENGINEERING

ASSESSMENT TOOL 1 – ANSWER SCRIPT

Course Code:	CSA51	Course Name:	Cryptography and Network Security
Register No:	192521079	Course Outcome:	CO5 (BL5, BL6)

Annexure A – Constraint-Based Problem Solving

Question 1 (5 Marks)

A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Problem Understanding

The institution must migrate to TLS for strong security while roughly 20% of its client base still runs software that only speaks SSL. The core conflict is between enforcing modern cryptographic standards and preserving service continuity for legacy clients, without exposing sensitive financial data to weak SSL cipher suites or causing prolonged downtime.

Constraint Analysis (priority order)

- **B – No sensitive data over SSL (highest priority):** This is a hard security/compliance constraint; violating it risks data breach and regulatory penalties, so it cannot be traded off.
- **A – 20% legacy compatibility:** A business-continuity constraint; must be satisfied but only for non-sensitive or read-only interactions, never for payment/authentication data.
- **C – Minimal downtime:** Operational constraint; migration must be phased/rolling rather than a hard cut-over.
- **D – Cost optimization:** Lowest priority; addressed through software-level (not hardware) solutions.

Proposed Solution

- Deploy a **TLS-terminating reverse proxy / load balancer** (e.g., an SSL offloading gateway) in front of the application servers, configured to accept only TLS 1.2/1.3 for all connections carrying authentication, card, or account data.
- For the legacy 20%, route them to a strictly isolated, non-financial 'informational' endpoint (e.g., branch locator, public FAQs) over SSL with additional compensating controls (WAF, network segmentation); no monetary transaction is ever permitted on this path.
- Use a **protocol downgrade dashboard** to identify and proactively notify legacy clients, giving a fixed sunset date (e.g., 90 days) after which SSL access is fully disabled.
- Perform the cut-over in **rolling batches per data center/region** using blue-green deployment so TLS enforcement rolls out with near-zero downtime.
- Use open-source components (OpenSSL, HAProxy/Nginx) for offloading to keep implementation cost low, avoiding proprietary hardware SSL accelerators.

Justification

This design satisfies constraint B absolutely (no sensitive data ever traverses SSL), meets constraint A through a time-boxed, restricted fallback rather than open-ended support, achieves constraint C via phased rollout instead of a single risky cut-over, and keeps constraint D low by relying on software-based TLS termination rather than new hardware.

Question 2 (5 Marks)

An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Problem Understanding

The platform must decide between adopting Secure Electronic Transaction (SET) — which offers strong dual-signature, cardholder-merchant-bank authentication but is complex and largely obsolete — versus continuing/enhancing its existing TLS-based payment security, while meeting throughput, browser compatibility, low complexity, and PCI-DSS compliance requirements.

Constraint Analysis (priority order)

- **D – PCI-DSS compliance (highest priority):** Non-negotiable regulatory requirement for any card-processing platform.
- **A – 10,000 transactions/minute throughput:** SET's heavy cryptographic overhead (dual signatures, certificate chains, multiple round trips) makes it unsuitable at this scale.
- **B – Modern browser compatibility:** SET requires special digital-wallet client software that modern browsers/mobile apps no longer support natively, whereas TLS is natively supported everywhere.
- **C – Minimize implementation complexity:** SET involves a complex PKI with certificates for cardholder, merchant, and bank; TLS with tokenization is comparatively simple to deploy and maintain.

Proposed Decision

- **Reject SET** and retain a TLS 1.3-based architecture, since SET is effectively deprecated in the industry and cannot meet the throughput or compatibility constraints.
- Strengthen the existing TLS channel with **tokenization and EMV 3-D Secure (3DS2)** to reproduce SET's key benefit (strong cardholder authentication) without its overhead.
- Ensure the platform never stores raw card data (use a PCI-DSS validated payment gateway/tokenization vault) so full PCI-DSS scope and compliance are satisfied.
- Use TLS session resumption and hardware-accelerated cipher suites to sustain the required 10,000 transactions/minute.

Justification

TLS + tokenization + 3-D Secure delivers equivalent or better transaction security than SET while being natively supported by every modern browser, scaling to the required throughput, and requiring far less implementation and certificate-management complexity — directly satisfying all four constraints, whereas SET would fail constraints A, B, and C.

Question 3 (5 Marks)

A corporate network is experiencing repeated malware infections that spread rapidly without user interaction. Propose a containment and prevention strategy.

Problem Understanding

Self-propagating, no-user-interaction spread is the defining behavior of a **worm** (as opposed to a virus, which needs a host file/user action, or a Trojan, which relies on deception). Across 500+ interconnected systems the strategy must detect infection within 2 minutes, contain it with under 10 minutes of downtime per host, and correctly classify the malware type before response.

Constraint Analysis (priority order)

- **C – Detection within 2 minutes:** Highest priority; late detection allows a worm to spread exponentially across all 500+ hosts.
- **D – Differentiate virus/worm/Trojan:** Correct classification drives the correct response (e.g., network isolation for worms vs. file quarantine for viruses vs. process/registry cleanup for Trojans).
- **A – Scale (500+ systems):** Requires centralized, automated tooling rather than manual per-host response.
- **B – Downtime $\leq$ 10 minutes/system:** Response actions must be surgical (segment-level isolation) rather than network-wide shutdown.

Proposed Strategy

- Deploy a **network-based IDS/IPS with behavioral and signature analysis** (e.g., anomaly detection on lateral movement, port-scan patterns, SMB/RPC exploitation attempts) to flag worm-like propagation within the 2-minute window.
- Use **EDR (Endpoint Detection & Response)** agents on all hosts to distinguish worm behavior (self-replication over the network) from virus behavior (file infection) and Trojan behavior (disguised payload, C2 communication), enabling type-specific response.
- On detection, trigger **automated micro-segmentation / VLAN quarantine** for the infected subnet only — isolating spread while leaving unaffected systems online, keeping downtime per system under 10 minutes.
- Patch the exploited vulnerability network-wide and push updated signatures via a centralized management console to prevent re-infection.
- Maintain offline/immutable backups and a tested incident-response runbook so infected systems can be restored quickly within the downtime budget.

Justification

Combining network IDS/IPS (fast detection) with EDR (accurate classification) and automated micro-segmentation (fast, scoped containment) satisfies the 2-minute detection and 10-minute downtime constraints simultaneously, scales to 500+ systems through automation, and explicitly differentiates malware types to ensure the correct remediation is applied.

Question 4 (5 Marks)

An organization needs to deploy a firewall architecture to protect its internal network from external threats and insider attacks. Design the solution.

Problem Understanding

The organization needs defense against both external attackers and insider threats, which means perimeter-only filtering is insufficient — internal traffic must also be inspected. The design must combine packet filtering and application-layer inspection, sustain 1 Gbps throughput, add at most 5 ms latency per request, and still allow secure remote employee access.

Constraint Analysis (priority order)

- **A – Packet filtering + application-level inspection:** A functional requirement that determines the architecture (a single-layer firewall cannot meet it).
- **C – 1 Gbps throughput:** Determines hardware/placement choices — deep inspection must be hardware-accelerated to avoid becoming a bottleneck.
- **B – ≤ 5 ms latency:** Constrains how much application-layer inspection can be done inline; favors ASIC/NPU-accelerated appliances over pure software firewalls.
- **D – Secure remote access:** Adds a VPN/Zero Trust access requirement that must not itself violate the latency or throughput budget.

Proposed Architecture

- Implement a **three-tier (screened subnet / DMZ) architecture**: an outer packet-filtering firewall facing the internet, a DMZ hosting public-facing services, and an inner Next-Generation Firewall (NGFW) facing the internal LAN.
- The NGFW performs **stateful packet filtering plus application-layer (Layer 7) inspection** (deep packet inspection, intrusion prevention, application-aware rules) to meet constraint A.
- Use hardware-accelerated NGFW appliances rated above 1 Gbps throughput with dedicated inspection ASICs to satisfy constraint C without exceeding the 5 ms latency budget (constraint B).
- Segment the internal network with **internal firewalls / micro-segmentation** between departments so insider attacks or lateral movement from a compromised internal host are also filtered, not just north-south traffic.
- Provide employee remote access via an **SSL/TLS VPN or Zero Trust Network Access (ZTNA) gateway** integrated with the NGFW, enforcing MFA and least-privilege access rather than full network trust.

Justification

The DMZ + internal-segmentation design addresses insider threats (constraint implicit in the problem) as well as external ones, the NGFW satisfies the dual filtering requirement, hardware acceleration meets the throughput/latency budget together, and a ZTNA/VPN gateway fulfils secure remote access without reintroducing the insider-trust problem the internal segmentation was designed to prevent.

Question 5 (5 Marks)

A large enterprise network generates excessive false positives in its IDS, leading to alert fatigue. Propose an optimized IDS/IPS solution.

Problem Understanding

The existing IDS is over-alerting, causing analysts to ignore or miss genuine threats (alert fatigue). The redesigned solution must raise detection accuracy to at least 95%, cut the false-positive rate below 5%, keep pace with 2 Gbps of real-time traffic, and integrate with the firewall already in place.

Constraint Analysis (priority order)

- **B – False positive rate < 5% (highest priority, root cause):** Directly addresses the alert fatigue problem stated in the scenario.
- **A – Detection accuracy ≥ 95%:** Must be improved without being achieved by simply lowering sensitivity (which would raise false negatives), so it is tightly coupled with constraint B.
- **C – 2 Gbps real-time processing:** Any added analysis (e.g., machine learning correlation) must be performant enough not to introduce detection lag.
- **D – Integration with existing firewall:** An architectural constraint ensuring the new IDS/IPS complements rather than replaces current infrastructure.

Proposed Solution

- Move from a purely **signature-based IDS to a hybrid signature + anomaly-based (ML-driven) IDS/IPS**, where signatures catch known attacks precisely (low false positives) and a trained anomaly model flags novel behavior, with confidence scoring to suppress low-confidence alerts.
- Apply **alert correlation and prioritization (SIEM/SOAR integration)** so multiple low-level events are consolidated into a single high-fidelity incident instead of many redundant alerts, directly reducing false positives below 5%.
- Continuously **tune detection thresholds and retrain the ML model** using labeled traffic from the organization's own network (baseline-aware tuning) to push accuracy above 95%.
- Deploy the sensor **inline with hardware/NPU acceleration** capable of 2 Gbps line-rate inspection so added analytics do not degrade throughput.
- Configure the IDS/IPS to **share threat intelligence and blocking rules bidirectionally with the existing firewall** (e.g., via a common management plane or API) so verified threats are auto-blocked at the perimeter.

Justification

Combining signature accuracy with tuned anomaly detection and SIEM-level correlation is the standard way to simultaneously raise true-positive accuracy and suppress false positives — directly resolving alert fatigue — while hardware acceleration preserves 2 Gbps throughput and firewall integration ensures the solution strengthens, rather than duplicates, existing defenses.